

PROJECT SYLORA 2

Executive Audit Summary

Baseline state assessment · 2026-08-13

Evidence-based forensic audit

SYLORA — Full Forensic Audit (Source of Truth)

Project: Project Sylora 2 (SYLORA)

Audit date: 2026-08-13

Auditor: Cloud forensic pass (code + runtime + screenshots)

Branch baseline: `main` @ forensic run

Rule: Claims require evidence. README and prior agent reports were not trusted without verification.

Related documents

Document	Path
Architecture (as-is)	SYLORA ARCHITECTURE MAP.md
UI map	SYLORA UI MAP.md
Real vs Mock	SYLORA REAL VS MOCK.md
Duplication	SYLORA DUPLICATION REPORT.md
Security	SYLORA SECURITY AUDIT.md
Production readiness	SYLORA PRODUCTION READINESS.md
Remediation roadmap	SYLORA REMEDIATION PLAN.md
Screenshots	/workspace/audit/screenshots/desktop/ , mobile/

1. Executive summary

SYLORA is a **monolithic Node.js application** serving a **vanilla JS SPA** (~897 LOC frontend, ~6500 LOC backend core+ecosystem) with **296 HTTP endpoints**, optional **PostgreSQL/Redis**, and **OpenAI** integration. The product presents a **broad surface area** (social, live, AI, business OS, science, gifts) but **most capabilities are UI + API stubs** backed by JSON file storage in dev.

Completion (weighted, honest)

Metric	%
Overall SYLORA completion	27%
UI completion	68%
Functional completion	22%
Backend completion	48%
End-to-end completion	14%
Production readiness	18%

Module counts

Category	Count
Verified 100% working (strict E2E)	4
Partial	45
Mock/static	12
Broken	1
Missing	15
P0 blockers	4
P1 issues	12

2. What was run (evidence log)

Check	Result	Evidence
npm install	PASS	59 packages, 0 vulns
npm run lint	PASS	exit 0
npm run build	PASS	syntax-check only
npm test	134/134 PASS	DATABASE_URL= REDIS_URL= empty
Server node src/server.mjs	PASS	:8787
GET /api/health	ok, json-dev-runtime	runtime curl
Register → post → gift → live	PASS	node runtime script
AI chat	503 AI_PROVIDER_NOT_CONFIGURED	expected without key
Docker compose	NOT RUN	docker not installed
Browser screenshots	22 captured	audit/screenshots/
WebRTC live/calls	NOT VERIFIED	requires browser media
Postgres production mode	NOT VERIFIED	no DB in audit env

3. Inventory (repository map)

See [SYLORA ARCHITECTURE MAP.md](#).

Applications: 1 (Node server + static SPA)

Packages: root only (`sylora@0.1.0`)

SDK: `sdk/js/` minimal

Database: `infra/postgres/schema.sql` + migrations 002-012

Docker: Dockerfile + compose.yaml

CI/CD: none

Tests: 134 files in `tests/`

Assets: ~45MB PNG in `public/assets/`

Deprecated: old `docs/audit/`, `renderProfileLegacy`, patch scripts

4. UI / navigation audit

Full per-page detail: [SYLORA UI MAP.md](#).

Navigation issues found

Issue	Severity
/videos , /gifts , /ai not in left rail (by design but hidden)	P3
Duplicate wallet surfaces (header, profile, gifts)	P2
LIVE "Following" always empty	P2
Admin only via More grid	OK
Locale selector offers 14 langs; server PATCH only uk/pl/en	P2
No Google sign-in button	P1 product gap

Proposed unified IA (not implemented)

Home | Live | Create▼ | Discover | Messages | Sylora | Profile
Settings▼ → Identity, Security, Business tools, Developer, Admin

5. Button interaction matrix

Control	Status	Evidence
Register (API)	WORKING	POST 201 runtime
Register (UI form)	PARTIAL	Same API; not browser-automated
Login	WORKING	API 401 on bad creds
Logout	WORKING	API 200
Google auth	MISSING	No UI/route
Profile edit	PARTIAL	PATCH /api/me exists
Follow/like/comment	PARTIAL	API exists
Language selector	WORKING	onchange → setLocale + PATCH (app.js account())
Messages/calls	PARTIAL	API; WebRTC BLOCKED
Start/join stream	PARTIAL	Create API OK; media BLOCKED
Gifts send	WORKING	POST 201 TEST LUMEN
Wallet/payments	MOCK	TEST label
Subscriptions	MISSING	—
AI interaction	BLOCKED	No OPENAI_API_KEY
Settings	WORKING	Navigation

6. Responsive audit

Viewport	Score	Notes
Mobile 360–412	68/100	Dock OK; tall heroes
Tablet	NOT VERIFIED	—
Desktop 1366–1920	72/100	Sidebar layout works

Issues: overflow rare; touch targets generally OK; modals not fully tested; keyboard safe areas partially via CSS `viewport-fit=cover`.

7. Design system audit

Verdict: Light futuristic SYLORA aesthetic **is present** (aurora, glass cards, horizon PNG) but **fragmented across 11 CSS files** with overlapping tokens.

Element	Consistent?
Typography	Mostly (Inter-like stack in styles.css)
Colors/gradients	Yes — warm light theme
Spacing/cards	Similar radius ~28px heroes
Dark dashboard drift	No — stays light
Icons	Mix emoji + unicode symbols
Loading/skeleton	Minimal spinners
a11y	Partial ARIA; contrast generally OK on light bg

Pages that feel like different products: **none severe** — consolidation CSS unified scenes per `data-view` .

8. Sylora AI audit

Capability	Status
Provider	OpenAI via <code>openai</code> npm ^7.4
Models	<code>OPENAI_MODEL</code> default gpt-5.6; realtime gpt-realtime-2.1
Backend	server.mjs + ecosystem/service.mjs
System prompts	personalityFor + contextPack per view
Tool calling	3 tools, 3-round max
Memory	JSON/PG; user + ai_confirmed sources
Streaming text	Via Responses API output_text (not SSE to client)
Voice	OpenAI Realtime HTTP SDP exchange
STT/TTS	Browser Speech + OpenAI transcription config
Multilingual	UI i18n; AI replies in user language (prompt)
Business/creator/education assistants	Ecosystem personas — PARTIAL
Live co-host	living-sylora + hooks — BLOCKED without AI
Moderation	Safety filter patterns in living-sylora
Rate limit	12/min/user AI
Fallback	503 when no key; lexical search fallback
Cost controls	trackAiUsage in ecosystem — not verified

Readiness	%
AI UI	75%
AI backend	55% (code) / 0% live without key
Voice	40% code / BLOCKED
Memory	70%
Live co-host	15%

9. Living Sylora / Avatar audit

Feature	Reality
Model format	PNG sprite sheets (not GLB/GLTF)
Renderer	DOM + CSS + <code></code> layers
Skeleton/rig/blendshapes	NOT SUPPORTED BY CURRENT MODEL
Blinking/gaze	CSS classes + JS timers — REAL
Lipsync	CSS viseme grid from audio bands — FAKE/SIMULATION
Emotions	PNG atlases exist; limited use in AI hero
Voice sync	Partial viseme frames
Realtime 3D	MISSING
Mobile performance	Heavy PNG loads (~2MB base avatar)

Classification: **CSS/PNG/SPRITE — NOT real 3D avatar.**

10. Live / streaming audit

Feature	Class
UI	UI exists
Create room	Functional locally (API verified)
WebRTC mesh	Prototype (code complete, not E2E tested)
RTMP/OBS ingest	Missing (companion is control bridge only)
Chat/likes/gifts	Functional locally (API + SSE)
Battles	Partial
Recording	Prototype (canvas capture in studio)
TURN	BLOCKED_EXTERNAL
Production-ready	No

11. Live gifts audit

Catalog: 10 gifts in `/api/gifts` (spark...infinite-sylora). Gift V2 passports: 20 named in `gift-v2/catalog.js`.

Gift tier	Renderer	Sound	Backend tx
basic-legendary v1 IDs	GPU Three.js procedural OR 2D atlas	gift-sfx.js	REAL in JSON; atomic in PG tests
phoenix-rebirth v2	WebGL + keyframe PNGs	physical-audio	Same send pipeline

Not a video gift system — interactive WebGL/Canvas with optional LIVE segmentation (**BLOCKED** without MediaPipe bundle).

12. Authentication audit

Flow	Result
Registration	PASS API
Login	PASS
Logout	PASS (even without token)
Session refresh	MISSING — single long-lived bearer
Recovery/verify	MISSING
Google/phone	MISSING
Protected routes	Client-side renderAuth + server 401
Admin	env email list → role admin
scrypt passwords	PASS (auth.mjs)
Token storage	localStorage — XSS risk

13. Backend API table

296 endpoints documented in architecture map. Summary:

Area	Endpoints	Frontend uses
Core social/live	~90	app.js
Ecosystem	~206	~140 via app.js, 5 command-palette, 1 obs-overlay
Backend-only	~150	No UI caller

Full METHOD | PATH table: `grep src/server.mjs + src/ecosystem/routes.mjs` or see subagent export in git history.

Status: Most return JSON; **live verification** only on subset without Postgres/OpenAI.

14. Database audit

Area	JSON dev	Postgres schema
Users/sessions	yes	users, sessions
Social	yes	posts, reactions, comments
Messages	yes	conversations, messages
Live	yes	live_rooms, live_messages + migration 012 state
Wallet/gifts	yes	wallets, ledger, gifts
AI	yes	ai_messages, ai_memories, ai_actions
Ecosystem	JSON blobs in store	migrations 010-011 ecosystem

Schema drift risk: server still writes many entities only to JSON store even when auth social PG enabled (communities, courses, videos, reports).

15. Performance

Item	Finding
public/assets	45MB
app.js	897 LOC single file — no minification
11 CSS files	Sequential blocking
Three.js vendor	~1MB+
Lazy loading	Minimal
Gift GPU	Can stress mobile GPU — quality governor exists
ffmpeg	Sync spawn blocks event loop during transcode

16. Accessibility

Check	Status
Keyboard nav	Partial — buttons focusable
Focus visible	CSS partial
Labels	Some aria-label
Contrast	Generally OK light theme
Touch targets	Mobile dock OK
Reduced motion	Respected in scheduleSyloraLife
Forms	Basic labels missing on some prompts

17. Test coverage truth

134 tests PASS — but they **do not** mean product-ready:

Layer	Covered?
Unit (parsers, gifts, motion)	Yes
API integration (in-memory server)	Yes — strong vertical slices
Postgres (pg-mem)	Yes
E2E browser	No
WebRTC	No
AI live OpenAI	Mock server only
Security penetration	No
Load	No

Critical flows **without** E2E tests: live viewer, calls, payments, OAuth, AI voice.

18. User journeys

Journey	Result	Break point
NEW: landing → register → home	PARTIAL	Home renders; onboarding MISSING
RETURNING: login → nav → profile	PARTIAL	API OK; full UI not browser-tested
AI: open → message → history	FAIL	503 no OpenAI key
CREATOR: studio → go live	BLOCKED	Camera/WebRTC not audited
VIEWER: discover → join → gift	PARTIAL	Gift send API OK; watch BLOCKED
SOCIAL: follow → message → call	PARTIAL	Calls BLOCKED
MONETIZATION: wallet → purchase	FAIL	TEST LUMEN only; no payments

19. Architectural problems (6–12 month risk)

1. **God files:** app.js, ecosystem/service.mjs — untestable UI/regression risk
2. **Dual persistence:** JSON + Postgres branches everywhere
3. **296 endpoints / 21 views:** massive backend-without-frontend debt
4. **In-process ffmpeg:** won't scale
5. **SSE fanout in memory:** won't scale without Redis (designed but optional)
6. **TEST LUMEN** misrepresents monetization
7. **Avatar marketing vs PNG reality** — trust risk
8. **No CI** — regressions undetected

20. TODO / placeholder scan

Signal	Count	Notes
renderProfileLegacy	1	dead
comingSoon i18n key	UI string only	
PAYMENT_PROVIDER	env blocked	
OAuth OAUTH_DOC	architectural	
mock in tests	legitimate	
Following tab empty	honest placeholder	

21. Weighted readiness by domain

Domain	%	Rationale
Frontend shell	72	All views render
Design/UI	65	Beautiful but fragmented CSS
UX	45	Many dead-end modules
Responsive	60	Mobile OK; tablet unverified
Backend	48	Wide API; many untested live
Database	40	Schema exists; dual-write
Authentication	35	Email/pass only
Sylora AI	12	Blocked without key
Avatar	20	PNG simulation
Voice	15	Blocked
Live streaming	25	API yes; WebRTC unproven
Social	30	Core post OK
Messaging	25	API exists
Calls	20	Code only
Gifts	40	Send OK; playback heavy
Wallet/payments	8	Mock currency
Creator tools	35	Studio UI + API
Business	30	JSON/ecosystem
Education	30	Free courses OK
Notifications	25	SSE exists
Analytics	10	Minimal
Admin	25	JSON reports
Security	42	Baseline headers/auth
Performance	35	Heavy assets
Testing	38	Many unit, no E2E
DevOps	15	No CI
Production infra	18	Compose only

22. VERIFIED 100% WORKING (strict)

Only features with UI + backend + runtime verification:

1. **Static SPA shell + routing** (21 views resolve, server fallback)
2. **Health / ready probes**
3. **Email/password register + login** (JSON mode, scrypt, bearer token)
4. **Create text post + list feed** (API runtime)

Everything else missing at least one of: browser E2E, Postgres mode, external provider, or media permissions.

23. Candidates for deletion (do not delete in audit)

See [SYLORA DUPLICATION REPORT.md](#).

Top candidates: `renderProfileLegacy`, unused expression PNG v1, old audit markdown claims, redundant design CSS after merge, backend-only experimental endpoints without product owner.

24. Missing as a product (strategic)

- Real identity (OAuth, verify email)
- Working AI as differentiator (currently off)
- Proven live streaming with discovery loop
- Real money loop (not TEST LUMEN)
- Trust & safety ops (reports in JSON, no workflow)
- Recommendation/discovery (search only)
- Network effects (Following live empty)
- Mobile apps
- Compliance (delete account, DPA)
- Observability and on-call

25. P0 / P1 classification

P0 — Blockers

1. No CI/CD
2. Production persistence not enforced
3. AI provider not configured (if AI is core promise)
4. WebRTC TURN missing for live product claim

P1 — Critical

- TEST LUMEN presented as currency
- Media GET without auth
- No Google auth / recovery
- Avatar capability misrepresentation risk
- 150 orphan APIs increase attack surface

26. Audit methodology notes

- Prior `audit/AUDIT_REPORT.md` claims about `ownWeather` / `getThree` **were false positives** — symbols not in repository.
- Language selector **does work** (contrary to interim browser report).
- Three.js: `importmap` + relative imports; vendor addons use bare `three` — works in modern browsers with `importmap`.

27. Change log (audit-only)

No product code modified. Added:

- docs/audit/SYLORA_*.md (this bundle)
- audit/screenshots/** (22 webp)
- audit/INDEX.md , SUMMARY.txt , AUDIT_REPORT.md (working notes)

End of source-of-truth audit. Next step: approve [SYLORA REMEDIATION PLAN.md](#) before any fixes.